Risk ID	STRIDE	Risk Name	Risk Description	Affected Assets	D	R	E	A	D	Base DREAD	Threat Landscape	NIST Regulatory Impact	Business Context	Likelihood	Impact	Risk Level	Mitigation	What happens if not mitigated	Risk Appetite Notes
S-01	Spoofing	Azure AD Credential Phishing	Attacker phishing Azure AD credentials to impersonate a legitimate user	User accounts, Azure AD tokens, Backend API, SQL Database	8	9	8	7	7	39/50	High	IA (Identification & Authentication), AC (Access Control)	Normal Operations	4 (High)	4 (High)	16 (High Risk)	Enforce MFA, phishing-resistant authentication, user awareness training	Unauthorized access continues, gradual fraud and data exposure, regulatory violations	Risk tolerance is low for identity compromise in financial systems
S-01	Spoofing	Azure AD Credential Phishing	Attacker phishing Azure AD credentials to impersonate a legitimate user	User accounts, Azure AD tokens, Backend API, SQL Database	10	9	8	9	7	43/50	Very High	IA , AC	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Strict MFA enforcement, real-time fraud monitoring, SOC alert escalation	Large-scale fraud, significant financial loss, customer trust damage, regulatory violations	Same technical vulnerability becomes critical due to higher transaction volume and fraud impact
S-02	Spoofing	OAuth Token Replay	Attacker reuses a stolen JWT/OAuth token to impersonate a legitimate user	Azure AD Tokens, Backend API, APIM, SQL DB, Storage	7	8	7	6	6	34/50	High	IA , AC , SC(System & Communications Protection)	Normal Operations	3 (Medium)	4 (High)	12(High Risk)	Short token lifetimes, token binding, HTTPS everywhere	Continued unauthorized access, silent data theft, fraud	Organization has low tolerance for identity abuse affecting customer data
S-02	Spoofing	OAuth Token Replay	Attacker reuses a stolen JWT/OAuth token to impersonate a legitimate user	Azure AD Tokens, Backend API, APIM, SQL DB, Storage	7	8	7	7	7	36/50	High	IA , AC, SC	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	same mitigations + Enforce conditional access, tighter rate limits	Large-scale fraud, regulatory violations, customer trust loss	Risk exceeds appetite during peak revenue periods
S-03	Spoofing	Managed Identity Spoofing	Attacker gains code execution and abuses Managed Identity to obtain trusted service tokens	App Service, Managed Identity, Key Vault, SQL, Storage	9	8	8	9	8	42/50	High	IA , AC , SC	Normal Operations	3 (Medium)	5 (Critical)	15 (High Risk)	Restrict MI permissions, enforce least-privilege , isolate workloads, monitor token use	Attacker gains backend-level access to all critical services	Very low tolerance
S-03	Spoofing	Managed Identity Spoofing	Attacker gains code execution and abuses Managed Identity to obtain trusted service tokens	App Service, Managed Identity, Key Vault, SQL, Storage	9	8	8	9	9	43/50	High	IA, AC, SC	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Enforce MI scope isolation, privileged access reviews	Full system compromise and massive financial exposure	Completely unacceptable risk during peak periods
S-04	Spoofing	API Key / Header Spoofing	Attacker uses leaked API keys to bypass APIM authentication policies	APIM, Backend API, SQL, Storage	6	7	6	6	6	31/50	Medium	IA , AC , SC	Normal Operations	3 (Medium)	3 (Medium)	9 (Medium Risk)	Rotate keys, move to OAuth, suppress secrets in logs	Stealth abuse of APIs and data extraction	Moderate risk tolerated temporarily with monitoring
S-04	Spoofing	API Key / Header Spoofing	Attacker uses leaked API keys to bypass APIM authentication policies	APIM, Backend API, SQL, Storage	6	7	6	7	7	33/50	Medium	IA , AC , SC	Holiday / Peak Season	4 (High)	4 (High)	16 (High Risk)	Enforce stronger authentication, anomaly detection	Large-scale API abuse and financial loss	Risk not acceptable during peak business activity
T-01	Tampering	Data-in-Transit Tampering to Azure Storage	An attacker performs a Man-in-the-Middle attack on traffic between backend services and Azure Storage when Secure Transfer is disabled	Azure Storage, Transaction Files, Backend API, Audit Logs	8	7	6	7	6	34/50	Medium	SC, SI, CM	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	Enforce HTTPS/TLS, enable Secure Transfer Required, use hashing and integrity validation	Financial fraud and long-term corruption of transaction records	Integrity violations affecting transactions exceed organizational risk tolerance
T-01	Tampering	Data-in-Transit Tampering to Azure Storage	Same vulnerability exploited during peak transaction volume, increasing severity and financial impact.	Azure Storage, Transaction Files, Backend API, Audit Logs	9	7	6	9	6	37/50	High	SC, SI, CM	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Same controls + enhanced monitoring and alerting during peak times	Large-scale undetected financial fraud and regulatory breach	Zero tolerance during peak revenue periods
T-02	Tampering	Application Code Modification	Attacker with compromised deployment credentials injects malicious logic into application code, altering business behavior	App Service, Backend API, SQL Database	9	6	5	8	5	33/50	Medium	SC, SI, CM	Normal Operations	3 (Medium)	5 (Critical)	15 (High Risk)	Automate Security Scans Before Deployment,Enable (MFA)	Persistent fraud embedded in application logic	Very low tolerance for code integrity violations
T-02	Tampering	Application Code Modification	Malicious logic impacts significantly higher transaction volumes during peak season.	App Service, Backend API, SQL Database	10	6	5	9	5	35/50	High	SC, SI, CM	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Same controls + Enable Deployment Logs	Massive financial loss before detection	Not acceptable under any circumstances
T-03	Tampering	Trust-Based Data Tampering	Backend API blindly writes transaction files to storage without integrity validation, allowing manipulated data to persist.	Backend API, Azure Storage, Transaction Data	8	7	6	7	4	32/50	Medium	SC, SI, CM	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	File signing, checksum validation, integrity controls	Silent data corruption	Medium tolerance only if compensating controls exist
T-03	Tampering	Trust-Based Data Tampering	Increased data volume magnifies undetected corruption.	Backend API, Azure Storage, Transaction Data	9	7	6	9	4	35/50	High	SC, SI, CM	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Same controls+ runtime integrity monitoring	Large-scale financial manipulation	Unacceptable risk level
T-04	Tampering	Direct Database Data Manipulation	Attacker directly updates or inserts records in SQL using stolen credentials or managed identity.	Azure SQL Database, Financial Records	10	6	6	10	5	37/50	High	AC, SI, SC	Normal Operations	4 (High)	5 (Critical)	20 (Critical Risk)	MFA, least privilege, SQL auditing	Legal and financial disaster	Zero tolerance
T-04	Tampering	Direct Database Data Manipulation	Peak usage increases blast radius of corrupted transactions.	Azure SQL Database, Financial Records	10	6	6	10	6	38/50	Very High	AC, SI, SC	Holiday / Peak Season	5 (Critical)	5 (Critical)	25 (Critical Risk)	Same controls + emergency access controls	Catastrophic regulatory and business failure	Absolutely unacceptable
R-01	Repudiation	Disabling Diagnostic & Application Logging	Attacker disables logging across App Service, APIM, Storage, and Backend API to prevent attribution of malicious actions.	Log Analytics, App Service, APIM, Azure SQL, Azure Storage	7	8	6	7	8	36/50	Medium	AU, IR	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	RBAC restrictions, alert on logging changes	Attacks occur without evidence; investigations fail	Organization has low tolerance for audit and compliance gaps
R-01	Repudiation	Disabling Diagnostic & Application Logging	Attacker disables logging across App Service, APIM, Storage, and Backend API to prevent attribution of malicious actions.	Log Analytics, App Service, APIM, Azure SQL, Azure Storage	9	8	6	8	8	39/50	High	AU, IR	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Same controls + automated integrity checks	High-value fraud and long undetected campaigns, regulators cannot be satisfied	Zero tolerance during peak revenue periods
R-02	Repudiation	Insufficient Application-Level Logging	Backend API fails to log identity, payload, or timestamps for transactions; actions cannot be correlated to user.	Backend API logs, Application logs, Transaction records, Payment audit trails	7	6	7	6	7	33/50	Medium	AU, RA	Normal Operations	3 (Medium)	3 (Medium)	9 (Medium Risk)	Implement structured logging with user/session IDs, include timestamps and payload hashes	Fraudulent transactions cannot be attributed	Low appetite for unverifiable transactions; logging is required
R-02	Repudiation	Insufficient Application-Level Logging	Same lack of application-level logs during high transaction volumes; correlation and investigation become much harder	Backend API logs, Application logs, Transaction records, Payment audit trails	8	6	7	8	6	35/50	High	AU, RA	Holiday / Peak Season	4 (High)	4 (High)	16 (High Risk)	Same controls + increased retention and real-time correlation alerts	High rate of untraceable fraud; investigations ineffective	Not acceptable during peak business periods
R-03	Repudiation	Shared Service Principal Usage	Multiple services and developers reuse the same Service Principal; all actions appear under one identity, preventing per-actor attribution	Service Principals, App Service, APIM, SQL, Key Vault audit trails	6	7	6	6	6	31/50	Medium	IA , AU	Normal Operations	3 (Medium)	3 (Medium)	9 (Medium Risk)	Assign unique managed identities per service, enforce least privilege, Enable logging on each identity	Insider or compromised developer actions cannot be separated; accountability lost	Medium tolerance only if temporary; long-term risk unacceptable
R-03	Repudiation	Shared Service Principal Usage	Shared principal abuse occurs during peak activity, making it easy for malicious actions to be hidden among legitimate service activity	Service Principals, App Service, APIM, SQL, Key Vault audit trails	7	7	6	8	6	34/50	High	IA, AU	Holiday / Peak Season	4 (High)	4 (High)	16 (High Risk)	Enforce per-service identities, require justification & rotation for shared creds, continuous audit trail per principal	Perfect deniability for attackers	Low appetite for lack of accountability during key periods
R-04	Repudiation	Destroying Evidence by Deleting Resources	Attacker with Contributor/Owner role deletes Log Analytics workspaces, storage backups, diagnostic settings and backups	Log Analytics, Backups, Storage accounts	9	6	5	8	7	35/50	Medium	IR, CP, AU	Normal Operations	2 (Low)	5 (Critical)	10 (Medium Risk)	restrict delete privileges, alert on deletion events	Forensic chain broken; evidence destroyed; legal/regulatory consequences severe	Zero tolerance for permanent evidence loss
R-04	Repudiation	Destroying Evidence by Deleting Resources	Same destructive actions during peak periods cause irreversible loss of critical audit & backup data when it matters most	Log Analytics, Backups, Storage accounts	9	6	5	9	8	37/50	High	IR, CP, AU	Holiday / Peak Season	3 (Medium)	5 (Critical)	15(High Risk)	same mitigations + pre-configured recovery plans	Permanent loss of forensic capability; inability to satisfy regulators	Absolutely intolerable during critical business periods
INF-01	Information Disclosure	Leaked Azure AD Access Tokens	Stolen OAuth/JWT tokens allow attackers to impersonate users and access backend APIs without re-authentication.	Azure AD, Web App, Backend API, Azure SQL, Azure Storage	8	7	7	6	6	34/50	High	AC, SC	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	Short-lived tokens, HTTPS everywhere, secure logging, user behavior analytics	Unauthorized data access, gradual data leakage, identity impersonation	Above appetite — sensitive identity data exposed
INF-01	Information Disclosure	Leaked Azure AD Access Tokens	Same vulnerability, but higher data volume and urgency during holidays increases damage.	Azure AD, Web App, Backend API, Azure SQL, Azure Storage	9	7	7	8	7	38/50	High	AC, SC	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Same controls + stricter monitoring and rate limits	Mass exposure of customer accounts and financial data	Completely unacceptable during peak periods
INF-02	Information Disclosure	Azure Storage SAS Token Leakage	Exposed SAS URLs grant direct access to storage containers bypassing application controls.	Azure Storage, Backups, Receipts, Documents	9	9	8	7	7	40/50	High	SC, AC	Normal Operations	3 (Medium)	5 (Critical)	15 (High Risk)	Short-lived SAS, IP restriction, private endpoints, scanning repos	Silent full data downloads	Very low tolerance for storage exposure
INF-02	Information Disclosure	Azure Storage SAS Token Leakage	High-volume files during holidays increase exposure severity.	Azure Storage, Backups, Receipts, Documents	10	9	8	9	8	44/50	High	SC, AC	Holiday / Peak Season	4 (High)	5 (Critical)	20 (High Risk)	Disable public access, rotate tokens, enforce zero-trust	Mass customer data breach	Zero tolerance
INF-03	Information Disclosure	Key Vault Secret Leakage	Secrets stolen via compromised Managed Identity or misconfigured Key Vault policies.	Key Vault, SQL, APIs, Storage	10	8	7	8	6	39/50	High	SC, SI	Normal Operations	3 (Medium)	5 (Critical)	15 (High Risk)	Least privilege, key rotation	Full system compromise	Unacceptable
INF-03	Information Disclosure	Key Vault Secret Leakage	Increased reliance on secrets during holidays increases outage and compromise impact.	Entire system	10	8	7	9	7	41/50	High	SC, SI	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Same controls + strict monitoring	Total business outage	Zero tolerance
INF-04	Information Disclosure	SQL Injection in Backend API	Unsanitized user input in Backend API allows an attacker to inject SQL queries, enabling unauthorized read access to sensitive databases including users	Backend API, Azure SQL Database, Customer Records, Payment Data, Audit Logs	9	8	8	9	7	41/50	High	SC, CI	Normal Operations	4 (High)	4 (High)	16 (High Risk)	Input validation and parameterized queries, Web Application Firewall (WAF), secure coding practices and code reviews	Sensitive customer and financial data exposed, regulatory penalties, reputational damage, and possible service shutdown.	Organization has very low risk appetite for database-level data exposure, even during normal operations.
INF-04	Information Disclosure	SQL Injection in Backend API	During peak traffic periods, SQL injection vulnerabilities are exploited to extract high-volume sensitive transaction	Backend API, Azure SQL Database, Customer Records, Payment Data, Audit Logs	10	8	8	10	7	43/50	High	SC, CI	Holiday / Peak Season	5 (Very High)	5 (Critical)	25 (Critical Risk)	Pre-holiday security testing, SQL injection scanning, 24/7 monitoring during peak periods	Mass financial data breach during peak revenue period, customer trust collapse, heavy GDPR/PCI penalties	Zero tolerance risk during peak season, data disclosure at this time is considered unacceptable to the business.
DoS-01	Denial of Service	API Request Flooding via Azure Front Door	A botnet floods Azure Front Door with a high volume of valid-looking HTTP/API requests	Azure Front Door, App Service, API Management, Backend API, Payment APIs	8	9	8	8	9	42/50	High	CP, SC	Normal Operation	4 (High)	4 (High)	16 (High Risk)	Azure Front Door WAF rules, rate limiting and bot protection, traffic profiling and alerts	Users cannot access the system, transactions fail, and operational downtime causes financial and reputational damage.	Business has low tolerance for availability risks during normal operations.
DoS-01	Denial of Service	API Request Flooding via Azure Front Door	High-volume traffic flooding during peak seasons overwhelms system capacity	Azure Front Door, App Service, API Management, Backend API, Payment APIs	9	9	8	10	9	45/50	Very High	CP, SC	Holiday / Peak Season	5 (Very High)	5 (Critical)	25 (Critical Risk)	Pre-scaling Front Door and backend, geo-blocking and anomaly detection, 24/7 SOC monitoring	Revenue loss during peak season, and customer trust collapse.	Zero tolerance for DoS during peak business periods.
DoS-02	Denial of Service	Backend API Resource Exhaustion	An attacker repeatedly triggers expensive Backend API operations, exhausting compute resources and database capacity	Backend API, Azure SQL Database, Azure Storage, App Service	8	8	7	8	7	38/50	Medium–High	SC, CP	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	Query optimization, API rate limits	Backend crashes intermittently, causing degraded user experience and lost transactions.	Moderate tolerance, but requires monitoring.
DoS-02	Denial of Service	Backend API Resource Exhaustion	Resource-intensive requests during peak load exhaust backend capacity faster, leading to full API outages.	Backend API, Azure SQL Database, Azure Storage, App Service	9	8	7	9	7	40/50	High	SC, CP	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	same controls + Pre-holiday performance testing	System appears online but cannot process transactions, leading to peak-season revenue loss.	Low appetite — backend stability is critical during peak periods.
DoS-03	Denial of Service	Azure Storage Throughput Exhaustion	Massive upload/download operations overwhelm Azure Storage throughput limits, disrupting file-based application functionality.	Azure Storage, Backend API, App Service, Transaction Records	7	8	7	7	6	35/50	Meduim	CP, SC	Normal Operations	3 (Medium)	3 (Medium)	9 (Medium Risk)	SAS scope restriction, Network controls	Delays in file processing and degraded application workflows.	Moderate tolerance during non-peak periods.
DoS-03	Denial of Service	Azure Storage Throughput Exhaustion	Storage overload during high-volume transaction periods blocks access to receipts, files, and backups.	Azure Storage, Backend API, App Service, Transaction Records	8	8	7	9	6	38/50	High	CP, SC	Holiday / Peak Season	4 (High)	4 (High)	16 (High Risk)	Same mitigation controls	Transaction confirmation failures and customer disputes.	Low — customer-facing failures unacceptable during peak season.
DoS-04	Denial of Service	Azure Key Vault Throttling	Flooding Key Vault with secret requests causes throttling, preventing applications from retrieving credentials and secrets.	Azure Key Vault, Backend API, App Service, SQL, Azure Storage	9	8	6	8	6	37/50	Medium–High	CP, SC	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	Secret caching, managed identity best practices	Partial system outages and authentication failures.	Moderate tolerance under close monitoring.
DoS-04	Denial of Service	Azure Key Vault Throttling	Key Vault throttling during peak traffic results in system-wide outages due to shared dependency failure.	Azure Key Vault, Backend API, App Service, SQL, Azure Storage	10	8	6	10	6	40/50	High	CP, SC	Holiday / Peak Season	4(High)	5 (Critical)	20 (Critical Risk)	same controls + Enable alerts for high request volume	Full platform outage during peak revenue window.	Zero tolerance — Key Vault availability is mission-critical.
EoV-01	Elevation of Privilege	Backend API Injection Leading to Admin Privilege Gain	Malicious input sent through the Web App or APIM is not properly sanitized by the Backend API	Backend API, Azure SQL Database, User Management System, Configuration Data	8	7	7	8	7	37/50	Medium–High	AC, SC, SI	Normal Operations	3 (Medium)	4 (High)	12 (Medium Risk)	Input validation, Apply strict API authentication Role-based access enforcement	Attackers gain persistent admin access and can manipulate users, transactions, and system configuration.	Medium tolerance; admin privilege misuse is serious but expected to be controlled through secure coding.
EoV-01	Elevation of Privilege	Backend API Injection Leading to Admin Privilege Gain	API injection during peak traffic allows attackers to hide malicious actions among legitimate requests, escalating privileges without detection.	Backend API, Azure SQL Database, User Management System, Configuration Data	9	7	7	9	7	39/50	High	AC, SC, SI	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	same controls + Turn on Azure WAF	Administrative abuse during revenue-critical periods leading to fraud and irreversible damage.	Low tolerance — admin compromise is unacceptable during peak operations.
EoV-02	Elevation of Privilege	Managed Identity Abuse via Compromised App Service	An attacker who gains code execution inside App Service abuses the Managed Identity endpoint to obtain backend-level access tokens.	Azure App Service, Azure AD, SQL Database, Key Vault, Storage Account	9	6	6	8	7	36/50	Medium	AC, IA, SI	Normal Operations	3 (Medium)	5 (Critical)	15 (High Risk)	Follow least privilege, Rotate secrets and credentials regularly, Use network restrictions	Attacker impersonates backend services and accesses all protected resources.	Low tolerance — backend identity abuse threatens the entire architecture.
EoV-02	Elevation of Privilege	Managed Identity Abuse via Compromised App Service	Under heavy load, Managed Identity abuse enables attackers to blend into legitimate backend token usage.	Azure App Service, Azure AD, SQL Database, Key Vault, Storage Account	10	6	6	9	7	38/50	High	AC, IA, SI	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	same controls + Use Azure Defender for Cloud to detect identity misuse	Full backend impersonation during peak season with massive financial impact.	Zero tolerance.
EoV-03	Elevation of Privilege	APIM Policy Misconfiguration Allowing Admin Access	Weak or missing authorization policies in API Management expose privileged admin endpoints.	API Management, Backend API, Admin APIs, Azure SQL	8	7	8	7	8	38/50	High	AC, IA, CM	Normal Operations	4 (High)	4 (High)	16 (High Risk)	Enforce strict APIM authentication and authorization policies, Protect admin APIs using TLS or private endpoints	Attackers can perform unauthorized administrative operations, modify and access sensitive data, and manipulate financial transactions.	Low tolerance. Any unauthorized elevation through the API gateway exceeds acceptable risk thresholds.
EoV-03	Elevation of Privilege	APIM Policy Misconfiguration Allowing Admin Access	Rapid API changes and emergency deployments bypass security review, leaving APIM admin endpoints exposed without proper authorization policies	API Management, Backend API, Admin APIs, Azure SQL	9	8	8	9	8	42/50	High	AC, IA, CM	Holiday / Peak Season	4 (High)	5 (Ctritical)	20 (Critical Risk)	Freeze APIM policy changes during peak periods, Enable WAF rules targeting admin endpoint probing	Attackers perform unauthorized admin actions during peak revenue periods, leading to financial fraud, system misconfiguration and loss of customer trust	Zero tolerance for admin-level privilege escalation during peak revenue periods
EoV-04	Elevation of Privilege	Malicious OAuth App Granted Excessive Permissions	A privileged user is tricked into granting a malicious OAuth app excessive permissions.	Azure AD, Backend APIs, Sensitive Business Data	8	6	7	7	6	34/50	Medium	AC, IA, SA	Normal Operations	3 (High)	4 (High)	12 (Medium Risk)	Require MFA for privileged users, Periodic OAuth app access reviews, Enforce admin-only consent for high-risk scopes	Attackers maintain stealthy long-term access to APIs and business data using legitimate OAuth tokens	Medium tolerance with awareness training.
EoV-04	Elevation of Privilege	Malicious OAuth App Granted Excessive Permissions	Stressed admins approve OAuth requests without validation during peak workloads	Azure AD, Backend APIs, Sensitive Business Data	9	6	7	10	6	37/50	High	AC, IA, SA	Holiday / Peak Season	4 (High)	5 (Critical)	20 (Critical Risk)	Block OAuth consent during peak periods unless emergency override is approved, Automated alerts for new OAuth app consent events	exposure of sensitive customer data, regulatory violations, and prolonged undetected access during the most critical business period.	Zero tolerance — privilege escalation via OAuth is unacceptable during peak business operations.